



Incident report analysis

Summary	On 25 April 2025, the DragonForce ransomware syndicate breached Co-op's network by exploiting compromised third-party vendor credentials. The attackers exfiltrated the data of 6.5 million members and attempted a network-wide encryption attack via corporate Microsoft Teams channels. In response, Co-op's incident management team aggressively isolated large sections of the corporate infrastructure, stock management systems, and branch networks. Although this emergency shutdown effectively stopped the ransomware from spreading and protected core financial data, it disconnected physical stores, causing logistics delays and local till failures.
Identify	• Type of attack: Double-Extortion Ransomware & Supply Chain Data Breach. • Threat Actor: DragonForce, a sophisticated "Ransomware-as-a-Service" (RaaS) syndicate. • The Exploit: The threat actors utilised Social Engineering (Identity Impersonation) • Systems impacted: ○ External Vendor VPN / Supply Chain Integration Hub ○ Customer Relationship Management (CRM) & Membership Directory ○ Corporate VPN, Administrative Networks, Internal Call Centres, and Microsoft Teams. ○ Local Store Payment Gateways and Contactless Tills
Protect	To further secure organisational assets and prevent recurrence:

	• Enforced Phishing-Resistant MFA: Mandated strict Multi-Factor Authentication across 100% of internal staff and external third-party supplier entry points • Revamped Helpdesk Verification Protocols: Restructured the IT Service Desk verification procedures. • Micro-Segmentation Expansion: Extended the existing network segmentation to further isolate back-office administrative networks.
Detect	What was done to detect the breach as early as possible: • Behavioural Identity Auditing: Co-op's Security Operations Centre (SOC) flagged suspicious and unusual activity coming from a third-party supplier's account. • Rapid Incident Window: The internal logging systems were highly optimised, allowing security teams to achieve full behavioural visibility and flag the compromised employee identity. • Real-Time Action Tracking: Because comprehensive logging was configured across the network layer, the incident response team could track the exact files the hackers touched.
Respond	The actions taken to manage, contain, and resolve a security breach: • Immediate Account Isolation: Locked out the compromised admin account within the hour to stop the attacker from moving further into the network. • Proactive Network Shutdown: Disconnected corporate IT and stock systems to limit the virus's spread and protect core financial data. • Branch Disconnection: Cut central network links to physical stores, causing temporary outages at local contactless payment tills. • VPN Lockdowns: Blocked all employee VPN access to ensure the hackers couldn't slip in through active remote staff sessions.
Recover	Steps to ensure business continuity and resilience:

	• Ransom Refusal & Rebuilding: Denied extortion demands and rebuilt compromised architecture entirely from secure, offline backups. • Staged System Restorations: Gradually reconnected network systems in a highly monitored loop over May 2025 to ensure no malware remained. • Payment Infrastructure Recovery: Fully restored front-end payment networks across all 2,300+ stores, bringing contactless and chip-and-PIN tills back online. • Member Support Initiatives: Launched customer reassurance campaigns, offering safety advice and discount vouchers to repair brand reputation.
My Notes/ Reflections:	As a Computer Science student passionate about pursuing a career in cybersecurity, witnessing the real-time fallout of the Co-op incident was incredibly fascinating. Analysing an event of this scale allows me to apply classroom theory to a real-world cyber crisis. Imagining myself as a SOC analyst or risk analyst on Co-op's response team, I immediately think about how I would have triaged the initial supplier-related anomaly, managed the high-pressure containment phase, and balanced operational uptime against critical security risks. During the recovery stage, when immediate pressures have begun to ease, I would advocate for continuous social engineering simulations and awareness training. Since the initial entry point reportedly relied on employee impersonation and helpdesk deception, traditional technical controls such as firewalls would have been ineffective against the attack. Co-op should therefore implement ongoing, adaptive social engineering and phishing simulation programmes. Employees across all departments should receive continuous training to recognise high-pressure psychological manipulation tactics. This would empower employees to remain alert, confident, and assertive when handling suspicious requests, while giving them a clear understanding of the warning signs that may indicate an attempted attack. One aspect of Co-op's response that stood out to me was its

	reported refusal to pay the DragonForce syndicate's extortion demands. I strongly agree with this decision. While some organisations view paying a ransom as a quick solution to minimise operational disruption, doing so introduces significant and often unmitigated business risks. Payment provides no guarantee that stolen data will be deleted, systems will be fully restored, or that attackers will not target the organisation again in the future. This approach is therefore more beneficial for the long-term security, resilience, and sustainability of the business.
--	---